

Auditoría y Métricas

Se deben de realizar revisiones periódicas al Sistema de Gestión de Seguridad de Información para medir la eficacia de los controles implementados, permitiendo obtener retroalimentación y realizar las medidas correctivas necesarias.

Las auditorías internas deben de ser realizadas por lo menos 1 vez cada año para determinar la conformidad con el SGSI y cumplir con los requisitos de la cláusula 9.2 del ISO 27001.

El auditor debe formar parte del Comité de Seguridad de la Información designado, así como contar con conocimientos profundos sobre la organización, sus procesos, políticas y objetivos.

Las auditorías externas obligatoriamente deben ser realizadas por auditores externos, quienes pueden provenir también de las partes interesadas de la organización.

El papel del auditor en la auditoría para ISO 27001 consiste en 2 actividades principales, las cuales son:

- Revisar la documentación de la organización para evaluar la adhesión a los principios de la norma para constar la integridad y adecuación del SGSI.
- Verificar la adhesión de la organización al estándar ISO, evaluando la eficacia de los controles del SGSI, donde al finalizar el proceso se labra un informe global resumiendo las conclusiones y no conformidades.

Indicadores de seguridad:

- **Número de incidentes de inyecciones de código malicioso:** Cantidad de eventos detectados donde se logró insertar código malicioso en aplicaciones o sistemas.
- **Número de incidentes causados por ransomware en servidores de producción:** Total de casos en los que servidores productivos fueron afectados por ransomware, comprometiendo su disponibilidad o información.
- **Número de incidentes por fallos con las credenciales de acceso:** Cantidad de incidentes relacionados con uso indebido, robo o mala gestión de credenciales de usuarios.
- **Número de filtraciones de datos por medio de la base de datos:** Total de incidentes donde información sensible fue expuesta o extraída desde bases de datos.
- **Cantidad de ataques de phishing exitosos ocurridos:** Número de veces que los usuarios fueron engañados y comprometieron información mediante ataques de phishing.

- **Cantidad de ataques DDoS a plataformas web:** Total de intentos de denegación de servicio distribuidos que afectaron la disponibilidad de plataformas web.
- **Número de filtraciones de datos por medio de correo electrónico:** Cantidad de incidentes donde se compartió o expuso información sensible a través de correos electrónicos.
- **Número de veces que los sistemas cayeron por mala configuración:** Total de interrupciones en los sistemas ocasionadas por errores de configuración.
- **Incidentes de fraude interno ocurridos en registros financieros:** Cantidad de eventos detectados de manipulación o alteración indebida en información financiera por personal interno.
- **Tiempo de respuesta a incidentes:** Tiempo promedio que toma al equipo de respuesta a incidentes realizar acciones correctivas a los incidentes ocurridos.
- **Proporción del personal capacitado:** Porcentaje de los empleados que han sido capacitados sobre temas de seguridad de la información, así como capacitaciones especializadas según sus roles y responsabilidades dentro de la organización.
- **Resultados finales de simulacros:** Calificación general obtenida al finalizar simulacros sobre temas de seguridad como phishing con el fin de evaluar la efectividad de las capacitaciones en los empleados.

Estos indicadores tienen como finalidad medir el nivel de cumplimiento de las políticas de seguridad y los planes de continuidad de la organización, así como evaluar la efectividad en la detección, gestión y respuesta ante incidentes de seguridad de la información.